UNIVERSIDAD AUTÓNOMA DE NUEVO LEÓN

FACULTAD DE INGENIERÍA MECÁNICA Y ELÉCTRICA

# Redes y Seguridad en Sistemas Distribuidos

**Actividad Fundamental 4**

**Sistemas Operativos**

**Equipo 1**

Grupo:003 | Hora: Martes V4-V6 | Aula: 1303

Profesora: Dra. Marín Martínez Norma Edith.

Fecha de entrega: 13 de octubre de 2026

**Integrantes del equipo**

| Matrícula | Nombre | Programa | Foto | Porcentaje de participación |
|---|---|---|---|---|
| 2144053 | Lozano Garza Camila del Carmen | IAS |  | 100% |
| 2160859 | Vera Moreno Oscar Elias | ITS |  | 100% |
| 2226699 | Sánchez Santiago Osmar Abdi | ITS |  | 100% |
| 2178081 | Cisneros Moreno Valeria Nohemí | ITS |  | 100% |
| 2144813 | Torres Guerrero David Alonso | ITS |  | 100% |
| 2065934 | Gonzalez Belloc Yael Ricardo | ITS |  | 100% |
| 2161066 | Ramirez Fabian Maria de los Angeles | IAS |  | 100% |

| Matrícula | Nombre | Programa | Foto | Porcentaje de participación |
|---|---|---|---|---|
| 2169669 | Sánchez Juárez Emiliano | ITS |  | 100% |
| 2097304 | Jaime Sebastian Esparza Leyva | ITS |  | 100% |
| 2158392 | Martinez Tamez Julio César | IAS |  | 100% |
| 2135792 | Muñoz Hernández Salvador | IAS |  | 100% |
| 1320176 | Maycott López Gilberto | IAS |  | 100% |

# Índice


Introducción ..... 7
Amenazas a la seguridad ..... 8
Objetivos de la seguridad ..... 8
Clasificación de las amenazas ..... 8
Tabla 1 - Clasificación de las amenazas según su efecto ..... 8
Diagrama 1 - Tipos de amenazas frente al flujo normal de información ..... 9
Por qué los sistemas distribuidos son más vulnerables ..... 9
Software malicioso (malware) ..... 10
Virus informáticos ..... 10
Gusanos ..... 10
Troyanos ..... 10
Spyware y adware ..... 10
Ransomware ..... 11
Botnets y cryptojacking ..... 11
Comparación entre tipos de malware ..... 11
Tabla 2 - Comparación de los principales tipos de malware ..... 12
Diagrama 2 - Clasificación del malware según su comportamiento ..... 13
Prevención y mitigación del malware ..... 13
Tipos de intrusos ..... 14
Hackers éticos, delincuentes y zonas grises ..... 14
Script kiddies ..... 14
Amenazas internas ..... 14
Tabla 3 - Clasificación de los intrusos ..... 15
Autenticación y control de acceso ..... 15
Identificación, autenticación y autorización ..... 15
Tipos de autenticación ..... 15
Figura 1 - Ejemplo de autenticación multifactor (MFA) ..... 16
Tabla 4 - Factores de autenticación ..... 16
Modelos de control de acceso ..... 16
Autenticación en red con Kerberos ..... 17
Figura 2 - Flujo básico de autenticación Kerberos ..... 19
Figura 3 - Ejemplo práctico del flujo Kerberos con Elliot.A ..... 19

Flujo detallado del protocolo Kerberos ....20
Figura 4 — AS-REQ sin pre-autenticación ....20
Figura 5 - Error KRB5KDC_ERR_PREAUTH_REQUIRED ....20
Figura 6 - AS-REQ con timestamp cifrado ....21
Figura 7 - AS-REP: respuesta del KDC con TGT ....21
Figura 8 - TGS-REQ: solicitud de ticket de servicio ....22
Figura 9 - TGS-REP: entrega del ticket de servicio ....22
Figura 10 - AP-REQ: solicitud al servidor de aplicación ....23
Diagrama 3 - Intercambio de mensajes del protocolo Kerberos ....24
PKINIT: autenticación con certificados ....24
Figura 11 - Pre-autenticación PKINIT con certificados X.509 ....24
Niveles de seguridad ....25
Diagrama 4 - Defensa en profundidad: niveles de seguridad ....25
Nivel usuario ....25
Nivel red ....25
Figura 12 - Ejemplo de segmentación de red con firewall ....26
Nivel empresa ....26
Diagrama 5 - Arquitectura Zero Trust según NIST SP 800-207 ....27
Implementación práctica de Zero Trust ....27
Tabla 6 - Medidas de seguridad por nivel ....28
Análisis de problemas y administración de riesgos ....28
Análisis de riesgos ....28
Figura 13 - Pasos para crear y usar un Perfil Organizacional del CSF ....29
Figura 14 - Uso del CSF para mejorar la comunicación de riesgos ....29
Diagrama 6 - Etapas del análisis de riesgos según NIST SP 800-30 ....30
Tabla 7 - Ejemplo de matriz de riesgos (1-6 bajo, 7-14 medio, 15-25 alto) ....30
Respuesta ante riesgos identificados ....31
Marcos de gestión de la seguridad ....31
Figura 15 - Estructura del CSF Core (Funciones, Categorías y Subcategorías) ....32
Figura 13 - Las seis funciones del NIST CSF 2.0 ....32
Figura 14 - Niveles (Tiers) del NIST CSF 2.0 ....32
Prevención de desastres y recuperación ....33
Prevención de desastres ....33

Plan de continuidad de negocio (BCP) ..... 33
Estrategia de respaldos 3-2-1-1-0 ..... 33
Figura 15 - Esquema visual de la estrategia 3-2-1-1-0 ..... 34
Tabla 8 - Componentes de la estrategia de respaldo 3-2-1-1-0 ..... 34
Tolerancia a fallos en sistemas distribuidos ..... 34
Tabla 9 - Comparación de algoritmos de consenso ..... 35
Algoritmos de consenso: Paxos, Raft y PBFT ..... 35
Figura 16 - Funcionamiento del algoritmo Raft ..... 36
Seguridad de hardware, software, archivos e información ..... 37
Seguridad del hardware ..... 37
Figura 17 - Medidas de seguridad física en centro de datos ..... 37
Seguridad del software ..... 37
Figura 18 - OWASP Top 10: riesgos de seguridad en aplicaciones ..... 38
Seguridad de los archivos ..... 38
Seguridad de la información ..... 38
Figura 19 - Tráfico cifrado con TLS en Wireshark ..... 39
Tabla 10 - Problemas frecuentes y soluciones por área ..... 39
Conclusión general ..... 40
Referencias ..... 41

# Introducción

La seguridad es una responsabilidad central de un sistema operativo, porque es quien controla el acceso a los archivos, a la memoria y a la red. Cuando enviamos un mensaje, pagamos en línea o guardamos una tarea en la nube, confiamos en que nadie más pueda leerla, cambiarla o dejarla inaccesible. En los sistemas distribuidos, donde muchos equipos trabajan conectados y se comunican por redes que no siempre son confiables, un solo punto débil puede comprometer a todos los usuarios.

Para estudiar el tema conviene separar tres ideas: una amenaza es cualquier circunstancia que puede causar daño; una vulnerabilidad es una debilidad que puede ser aprovechada; y el riesgo combina la probabilidad de que eso ocurra con el impacto que tendría. Un ataque sucede cuando una amenaza logra explotar una vulnerabilidad, y los controles de seguridad son las medidas que reducen esa posibilidad o limitan sus consecuencias.

Este documento revisa las amenazas que existen, los tipos de malware (virus, gusanos, troyanos, spyware, adware, ransomware y otros), los tipos de intrusos, las formas de autenticación y control de acceso, y los niveles de seguridad que pueden implementarse según se trate de un usuario, una red o una empresa. Después presenta el análisis de problemas, la prevención de desastres y la administración de riesgos, junto con medidas para proteger el hardware, el software, los archivos y la información. La idea central es que ninguna protección es perfecta: la seguridad se construye con varias capas y con una gestión continua del riesgo.

.

# Amenazas a la seguridad

## Objetivos de la seguridad

La seguridad informática busca proteger tres propiedades de la información y de los recursos: la **confidencialidad** (que solo quienes tienen permiso puedan ver los datos), la **integridad** (que los datos y programas no se modifiquen sin autorización) y la **disponibilidad** (que los recursos puedan usarse cuando se necesitan). A estas se suele añadir la **autenticidad**, que consiste en poder comprobar que un usuario, mensaje o proceso es quien dice ser. Cada amenaza afecta al menos una de estas propiedades.

## Clasificación de las amenazas

Las amenazas se pueden clasificar según lo que le hacen al recurso atacado (Tabla 1 y Diagrama 1). La **interrupción** ocurre cuando un recurso se destruye o deja de estar disponible. La **intercepción** se da cuando un tercero accede a la información sin autorización. La **modificación** consiste en alterar datos o programas sin permiso, y la **fabricación**, en insertar datos o procesos falsos en el sistema.

| Tipo | Qué ocurre | Propiedad afectada | Ejemplo |
|---|---|---|---|
| **Interrupción** | Un recurso se destruye o deja de estar disponible. | Disponibilidad | Saturar un servidor con tráfico (DoS), dañar un disco o cortar un enlace de red. |
| **Intercepción** | Un tercero accede sin autorización a información o recursos. | Confidencialidad | Capturar tráfico de red, copiar archivos o registrar las pulsaciones del teclado. |
| **Modificación** | Se alteran datos o programas sin permiso. | Integridad | Cambiar registros de una base de datos o modificar un programa ejecutable. |
| **Fabricación** | Se insertan datos, mensajes o procesos falsos. | Autenticidad | Crear cuentas o transacciones falsas, o enviar mensajes suplantando a otro usuario. |

*Tabla 1 - Clasificación de las amenazas según su efecto*

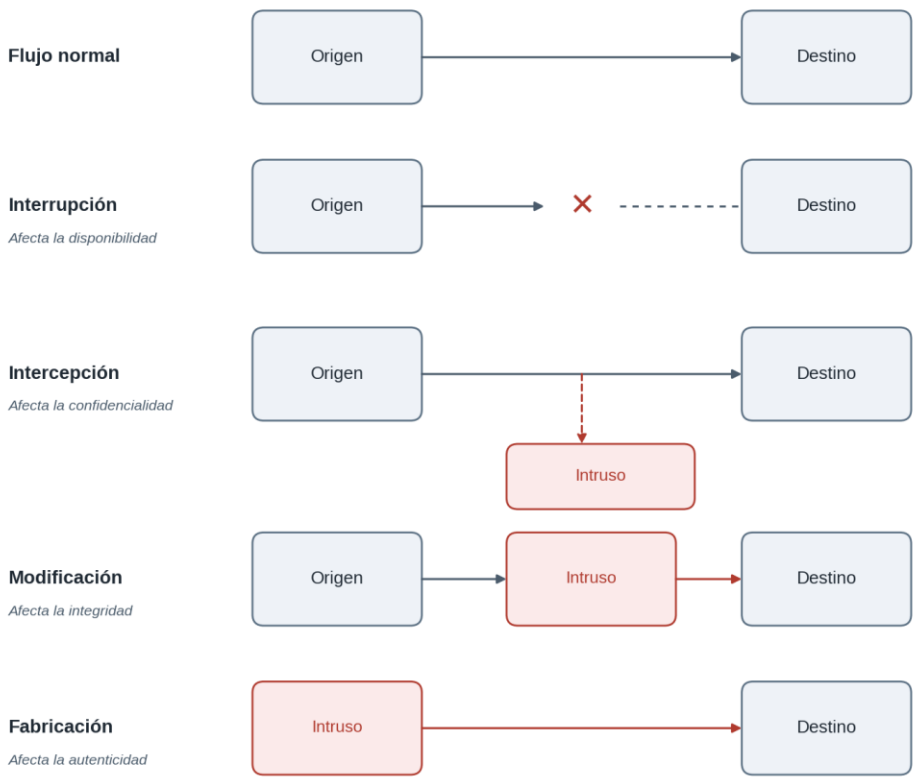



*Diagrama 1 - Tipos de amenazas frente al flujo normal de información*

Además del efecto, las amenazas se distinguen por su origen y su intención. Pueden ser **internas** (provienen de personas con acceso legítimo) o **externas**, y pueden ser **accidentales** —un error humano, una falla eléctrica, un desastre natural— o **malintencionadas**. Por eso la seguridad no trata solo de atacantes: también debe prever errores y fallas.

## Por qué los sistemas distribuidos son más vulnerables

En un sistema distribuido la información y los procesos se reparten entre varias computadoras conectadas por redes donde un agente externo podría interceptar, leer o inyectar paquetes. Esto amplía la superficie de ataque: cada nodo, cada servicio expuesto y cada canal de comunicación es un posible punto de entrada. Además, los nodos suelen confiar unos en otros, de modo que un equipo comprometido puede usarse para llegar a servidores más importantes. Por esta razón, la seguridad debe diseñarse por capas y no depender de un único mecanismo.

# Software malicioso (malware)

El malware (del inglés *malicious software*) es cualquier programa diseñado deliberadamente para infiltrarse, dañar, alterar o extraer información de un dispositivo, sistema o red sin el consentimiento del propietario. A diferencia de un error de programación, que causa fallos involuntarios, el malware es una herramienta ofensiva que aprovecha vulnerabilidades. Con el tiempo las categorías clásicas se han mezclado en amenazas híbridas, pero conocerlas sigue siendo necesario para diseñar defensas.

## Virus informáticos

Un virus es un fragmento de código malicioso que se adhiere a archivos o aplicaciones legítimas. Depende de que el usuario ejecute el archivo anfitrión para activarse y, cuando lo hace, se inserta en otros archivos del sistema. Su impacto va desde la lentitud hasta la corrupción total de los datos. Son ejemplos los virus de sector de arranque y los de macro en documentos de oficina. El virus Melissa, de 1999, se propagó por archivos adjuntos de correo en Word y Outlook, y se estimó que causó daños por 1,100 millones de dólares.

## Gusanos

Los gusanos (*worms*) son programas independientes que se autorreplican y se propagan por la red sin necesitar un archivo anfitrión ni la intervención del usuario. Aprovechan vulnerabilidades de protocolos y puertos abiertos, por lo que son especialmente dañinos en sistemas distribuidos: saturan el ancho de banda y la memoria, y pueden degradar la red como si fuera un ataque de denegación de servicio. Ejemplos conocidos son ILOVEYOU y la fase de propagación de WannaCry; Stuxnet, descubierto en 2010, alteró sistemas de control industrial y se considera un hito del ciberespionaje.

## Troyanos

Un troyano se presenta como software legítimo o deseable —un controlador, una utilidad gratuita, una actualización— para que la víctima lo ejecute. No se replica por sí mismo: depende de la ingeniería social o de descargas desde sitios comprometidos. Una vez instalado libera su carga útil (*payload*) y abre puertas traseras (*backdoors*) que permiten el acceso remoto, el robo de información o la instalación de otro malware. Entre sus variantes están los troyanos bancarios y los de acceso remoto (RAT). Zeus, activo desde 2007, robó millones de dólares al interceptar credenciales financieras, y Qbot y TrickBot evolucionaron hasta ser plataformas modulares usadas para distribuir otras amenazas.

## Spyware y adware

El spyware trabaja en segundo plano para recopilar datos sin que el usuario lo sepa: hábitos de navegación, información bancaria y pulsaciones del teclado mediante *keyloggers*, que permiten capturar contraseñas y conversaciones. Pegasus es un ejemplo conocido de software espía. El adware, por su parte, muestra publicidad no solicitada, cambia la configuración del navegador o redirige las búsquedas para generar ingresos con clics.

## Ransomware

El ransomware es un tipo de malware que cifra los archivos de la víctima y exige un rescate económico para liberarlos. A diferencia de otros malware que buscan robar información de forma silenciosa, el ransomware busca paralizar la operación y presionar a la organización para que pague rápidamente. Las cepas modernas no solo cifran los datos locales, sino que también buscan y cifran los respaldos conectados a la red, lo que hace indispensable la estrategia 3-2-1-1-0 que se describe más adelante. Algunas variantes incluso exfiltran datos antes de cifrarlos, para amenazar con publicarlos si no se paga (doble extorsión)

## Botnets y cryptojacking

Una botnet es una red de equipos infectados (bots) controlados remotamente por un atacante (botmaster) a través de un servidor de comando y control (C&C). Se usan para lanzar ataques DDoS, enviar spam masivo, minar criptomonedas o distribuir otro malware. El cryptojacking, por su parte, es el uso no autorizado de los recursos de cómputo de la víctima (CPU/GPU) para minar criptomonedas. A diferencia del ransomware, el cryptojacking no cifra datos: pasa desapercibido y solo se nota por el alto consumo de recursos y el aumento en la factura eléctrica.

## Comparación entre tipos de malware

La Tabla 2 resume las diferencias principales entre las categorías y el Diagrama 2 las agrupa según lo que hacen. La distinción más importante es cómo se propagan: el virus necesita un anfitrión, el gusano se mueve solo por la red y el troyano depende de engañar a una persona.

| Tipo | Cómo se propaga | ¿Se replica solo? | Objetivo | Impacto típico |
|---|---|---|---|---|
| **Virus** | Infecta archivos o programas anfitriones. | Requiere ejecutar el anfitrión. | Corromper archivos o alterar el sistema. | Pérdida de datos, fallos en aplicaciones. |
| **Gusano** | Explota vulnerabilidades de red (p. ej., SMB, RPC). | Sí, de forma autónoma. | Propagarse masivamente. | Saturación de la red, efecto similar a DoS. |
| **Troyano** | Ingeniería social, descargas falsas. | No. | Abrir puertas traseras y robar datos. | Robo de credenciales, control remoto. |
| **Spyware** | Incluido en troyanos o en exploits web. | No. | Vigilancia silenciosa. | Violación de la privacidad, fraude. |
| **Adware** | Instaladores con software adicional. | No. | Mostrar publicidad o redirigir. | Lentitud, exposición a sitios maliciosos. |
| **Ransomware** | Phishing, RDP expuesto, vulnerabilidades. | Variable (algunas cepas actúan como gusano). | Cifrar datos y exigir rescate. | Paralización operativa, pérdidas económicas. |
| **Botnet** | Infecciones previas por troyanos o gusanos. | Variable. | Reclutar equipos para ataques coordinados. | DDoS, spam masivo. |
| **Cryptojacking** | Navegadores o malware residente. | Variable. | Minar criptomonedas. | Bajo rendimiento, mayor consumo eléctrico. |

*Tabla 2 - Comparación de los principales tipos de malware*




*Diagrama 2 - Clasificación del malware según su comportamiento*

## Prevención y mitigación del malware

Ninguna medida detiene todas las amenazas, pero algunas combinan especialmente bien:

- **Protección del equipo:** antivirus o antimalware junto con soluciones EDR (*Endpoint Detection and Response*), que analizan el comportamiento y no solo las firmas conocidas.
- **Gestión de parches:** mantener actualizados el sistema operativo y las aplicaciones para cerrar vulnerabilidades, incluidas las de día cero una vez que se publican correcciones.
- **Control de accesos:** principio de mínimo privilegio (no trabajar a diario con la cuenta de administrador) y autenticación multifactor.
- **Respaldos periódicos:** aplicar la regla 3-2-1 (tres copias, dos medios distintos, una fuera de línea) para neutralizar el ransomware.

# Tipos de intrusos

Entender la seguridad no es solo analizar el código de un ataque: también hay que conocer a quién lo dirige, qué lo motiva y qué capacidades tiene. Los intrusos suelen clasificarse por su ética, su intención legal y su nivel técnico. La Tabla 3 los resume.

## Hackers éticos, delincuentes y zonas grises

Los **hackers éticos (White Hat)** son profesionales de seguridad, auditores y *pentesters* que buscan vulnerabilidades con autorización explícita del dueño del sistema, usan metodologías estructuradas y reportan lo encontrado para que se corrija antes de que lo aproveche un atacante real. En el extremo opuesto están los **Black Hat**, ciberdelincuentes motivados por el dinero, el espionaje, el hacktivismo o la destrucción. Desarrollan malware, forman botnets, venden información en foros clandestinos y están detrás de las campañas de ransomware; los grupos actuales funcionan como organizaciones jerarquizadas, con equipos para investigar vulnerabilidades, negociar rescates y lavar criptomonedas.

Los **Grey Hat** ocupan una zona ambigua: entran en sistemas sin autorización, pero sin intención destructiva. Suelen avisar a la organización afectada y buscar reconocimiento o una recompensa (*bug bounty*). Aun así, acceder sin permiso sigue siendo ilegal.

## Script kiddies

Los *script kiddies* son aficionados con poca comprensión de redes, criptografía o programación que ejecutan herramientas y scripts hechos por otros. Individualmente son poco peligrosos, pero su cantidad y la automatización de sus herramientas generan ruido constante y ataques oportunistas, como la alteración de páginas web (*defacement*).

## Amenazas internas

Las amenazas internas (*insiders*) son personas que ya tienen acceso legítimo: empleados actuales o anteriores, administradores, contratistas o socios. Pueden ser **maliciosas**, cuando buscan sabotear, robar propiedad intelectual o cometer fraude, o **negligentes**, cuando comprometen el sistema por incumplir políticas, configurar mal un servicio o caer en ingeniería social como el *spear-phishing*. Como el perímetro de la red no los detiene, se combaten con control de acceso, mínimo privilegio y auditoría.

| Tipo | Motivación | ¿Tiene autorización? | Nivel técnico | Característica principal |
|---|---|---|---|---|
| **White Hat** | Mejorar la seguridad. | Sí, explícita. | Alto | Auditorías y pruebas de penetración con metodología y reporte. |
| **Black Hat** | Lucro, espionaje, hacktivismo o destrucción. | No. | Alto | Desarrolla malware, vende datos y opera ransomware. |
| **Grey Hat** | Curiosidad, reconocimiento o recompensa. | No. | Alto | Vulnera sin permiso pero sin intención destructiva; avisa a la víctima. |
| **Script kiddie** | Diversión, presumir, oportunismo. | No. | Bajo | Usa herramientas automatizadas creadas por otros. |
| **Amenaza interna** | Venganza, lucro o descuido. | Sí (acceso legítimo). | Variable | Empleado, contratista o administrador; maliciosa o negligente. |

*Tabla 3 - Clasificación de los intrusos*

# Autenticación y control de acceso

## Identificación, autenticación y autorización

Antes de permitir un acceso, el sistema debe saber quién lo solicita y qué puede hacer. La **identificación** es declarar quién se es (un nombre de usuario); la **autenticación** es comprobarlo; la **autorización** define qué acciones se permiten una vez comprobada la identidad; y la **auditoría** registra lo que se hizo. En una red distribuida esto es más difícil, porque los mensajes viajan por canales donde pueden ser interceptados o repetidos.

## Tipos de autenticación

Existen varias formas de demostrar la identidad, que se agrupan en factores (Tabla 4). La contraseña es la más común, pero por sí sola es insuficiente: puede adivinarse, robarse con phishing o reutilizarse. Por eso se recomienda la autenticación multifactor (MFA), que exige al menos dos factores de categorías distintas, por ejemplo una contraseña y un código generado en el teléfono. CISA recomienda MFA resistente al phishing, como los tokens físicos, para VPN, correo y servicios de red privados. También se aplican bloqueos de cuenta para frenar la fuerza bruta y el password spraying, y el inicio de sesión único (SSO), que permite autenticarse una vez y acceder a varios servicios.

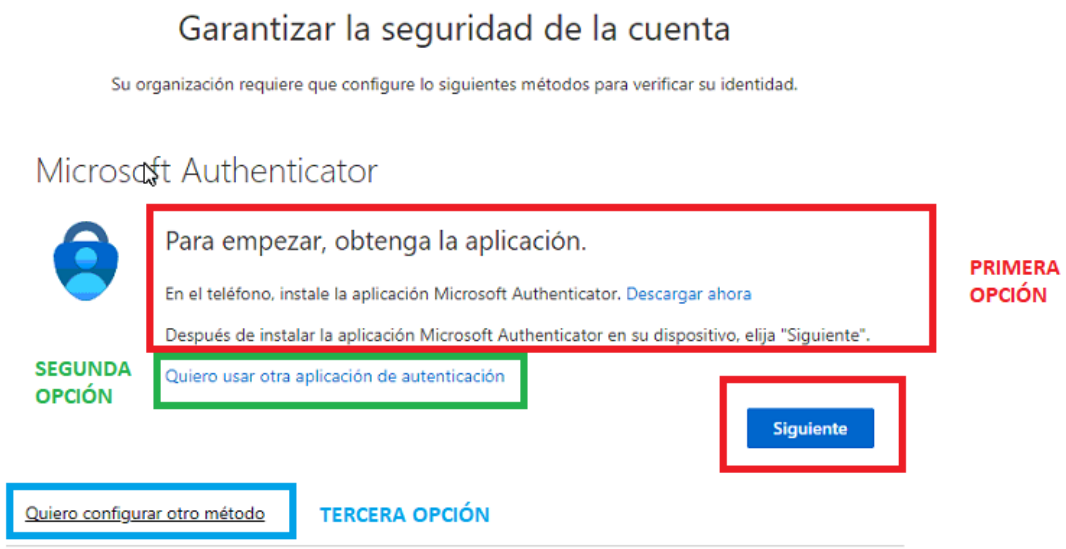



*Figura 1 - Ejemplo de autenticación multifactor (MFA)*

| Factor | Qué se verifica | Ejemplos | Riesgo principal |
|---|---|---|---|
| **Conocimiento** | Algo que el usuario sabe. | Contraseña, PIN, frase de acceso. | Robo por phishing, fuerza bruta o reutilización. |
| **Posesión** | Algo que el usuario tiene. | Token físico, tarjeta, app de códigos, teléfono. | Pérdida o robo del dispositivo. |
| **Inherencia** | Algo que el usuario es. | Huella digital, rostro, iris. | No se puede cambiar si se filtra; falsos positivos y negativos. |
| **Contexto** | Dónde, cuándo y desde qué equipo. | Ubicación de la IP, horario, estado del dispositivo. | Debe combinarse con otro factor; puede bloquear usuarios legítimos. |

*Tabla 4 - Factores de autenticación*

## Modelos de control de acceso

Una vez autenticado el usuario, el control de acceso regula la interacción entre sujetos (usuarios y procesos) y objetos (archivos, bases de datos, dispositivos). Los modelos más conocidos son DAC, MAC, RBAC y ABAC (Tabla 5). El **DAC** deja que el propietario del archivo

decida quién accede, lo que da flexibilidad pero también errores humanos. El **MAC** impone reglas centrales con etiquetas de sensibilidad y se usa en entornos militares o gubernamentales. El **RBAC** asigna permisos a roles como «Cajero» o «Administrador de sistemas», lo que simplifica la administración y apoya el principio de mínimo privilegio. El **ABAC** evalúa en el momento atributos del usuario, del recurso y del entorno; por ejemplo, puede negar el acceso a un servidor crítico si un administrador se conecta desde una red no segura de madrugada, aunque sus credenciales sean válidas.

Estos modelos se implementan en el sistema operativo mediante permisos y listas de control de acceso (ACL), que, como vimos en la actividad anterior, forman parte de los metadatos que el sistema de archivos guarda de cada archivo.

| Modelo | Quién decide | Ventaja | Limitación |
|---|---|---|---|
| **DAC (discrecional)** | El propietario del recurso. | Flexibilidad para equipos pequeños. | Poco control central; errores humanos y propagación de malware. |
| **MAC (obligatorio)** | El sistema, según etiquetas de sensibilidad y autorizaciones. | Alta confidencialidad y aislamiento. | Rígido y difícil de administrar a gran escala. |
| **RBAC (por roles)** | Los roles o funciones de la organización. | Escalable; simplifica la administración. | Puede haber «explosión de roles» si hay demasiadas excepciones. |
| **ABAC (por atributos)** | Reglas sobre atributos de usuario, recurso y entorno. | Decisiones granulares y dinámicas. | Implementación y procesamiento complejos. |

*Tabla 5 - Modelos de control de acceso*

## Autenticación en red con Kerberos

Kerberos es un protocolo de autenticación de red desarrollado en el MIT, cuyo nombre proviene del perro de tres cabezas que cuidaba el inframundo en la mitología griega. Su versión 5 está definida en el RFC 4120, que reemplazó al RFC 1510, y es la base de autenticación de Active Directory de Microsoft y de muchos entornos UNIX y Linux. Usa criptografía de clave simétrica y un tercero de confianza llamado Centro de Distribución de Claves (KDC), que contiene un Servidor de Autenticación (AS) y un Servicio de Concesión de Tickets (TGS).

Su ventaja principal es que la contraseña del usuario nunca viaja por la red: se usan tickets y claves de sesión. El proceso (Diagrama 3) tiene tres intercambios y seis mensajes:

1. **AS-REQ y AS-REP:** el cliente envía su usuario y una marca de tiempo cifrada con una clave derivada de su contraseña. Si el AS la valida, responde con un ticket de concesión de tickets (TGT), que solo el TGS puede leer, y una clave de sesión para comunicarse con el TGS.

2. **TGS-REQ y TGS-REP:** cuando el cliente quiere usar un servicio, presenta al TGS el TGT y un autenticador (su identidad con una nueva marca de tiempo). El TGS le entrega un ticket de servicio cifrado con la clave del servidor de destino.
3. **AP-REQ y AP-REP:** el cliente envía el ticket de servicio y un autenticador al servidor. Este los descifra, los valida y responde con la marca de tiempo del cliente más uno, lo que demuestra que el servidor también es legítimo (autenticación mutua).

El diseño supone que los relojes de los equipos están sincronizados, normalmente mediante NTP, porque la ventana de tiempo del autenticador es la defensa principal contra los ataques de repetición (*replay*).

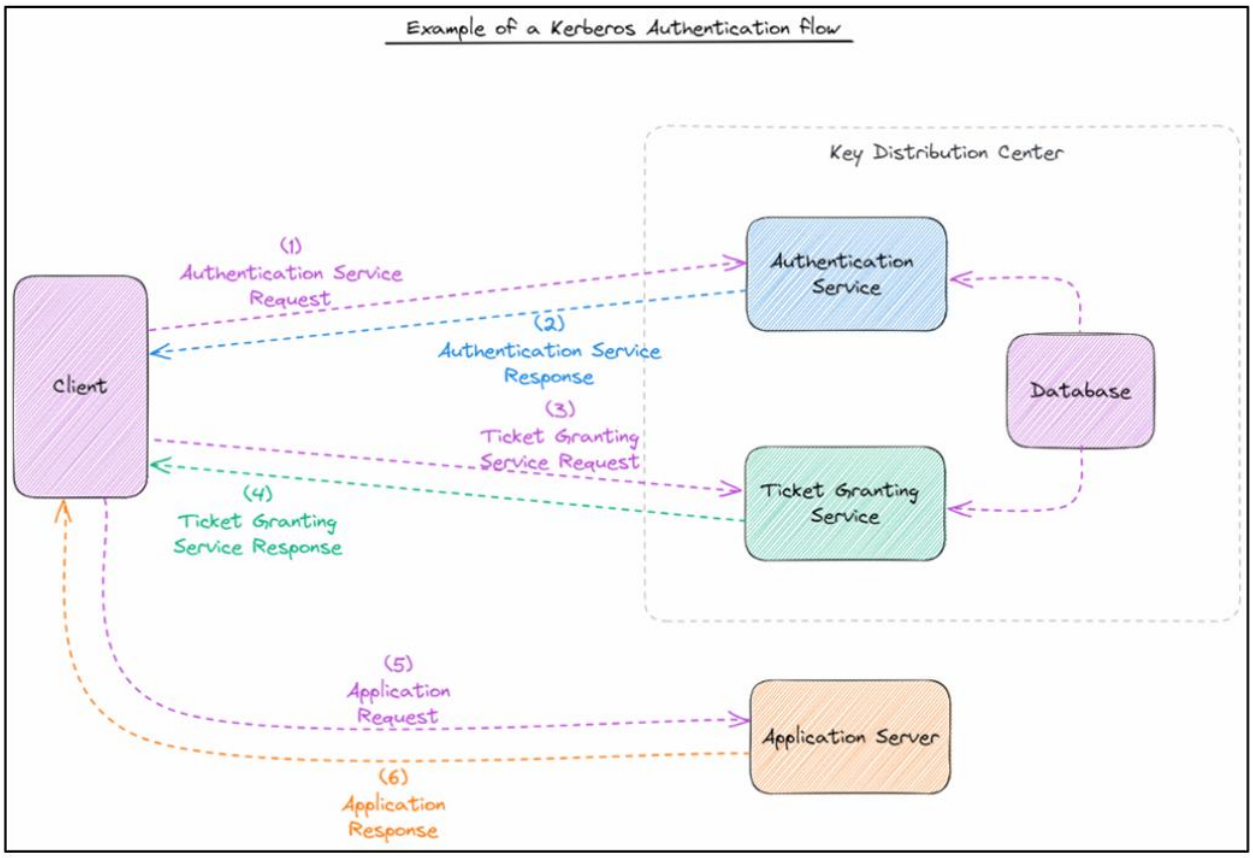



*Figura 2 - Flujo básico de autenticación Kerberos*

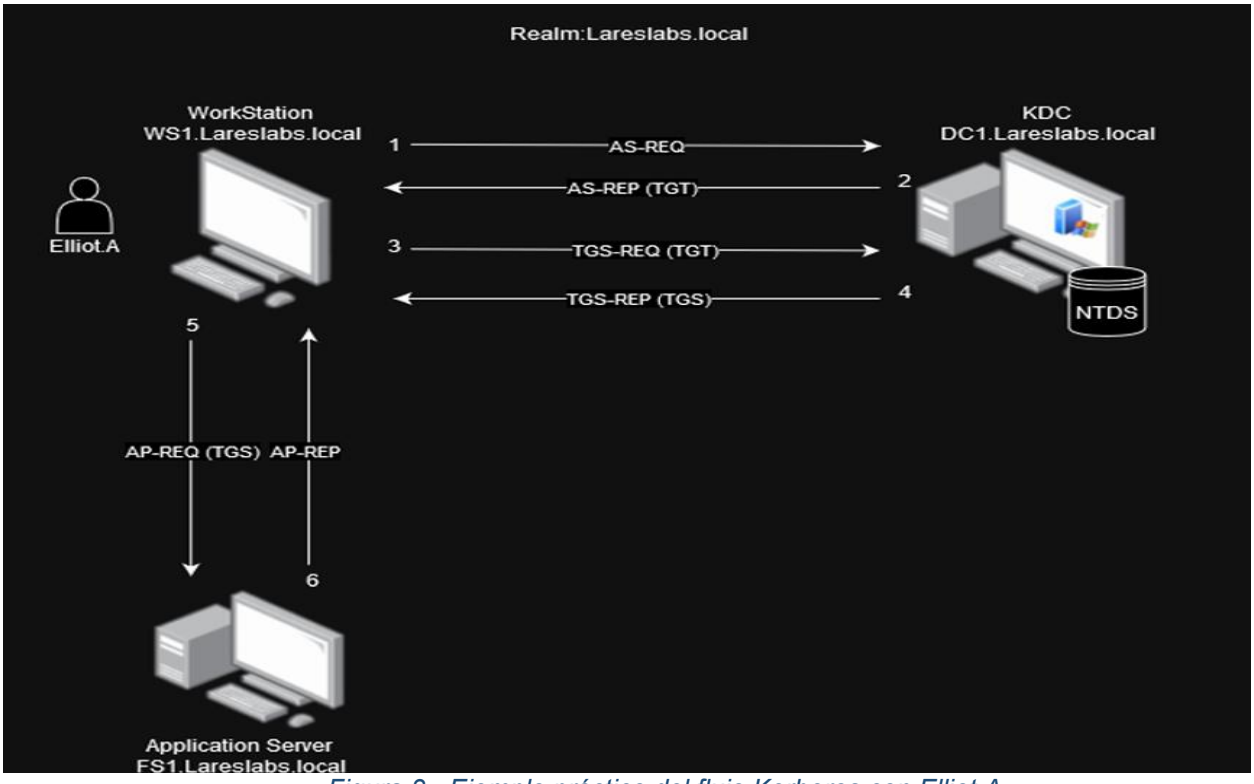



*Figura 3 - Ejemplo práctico del flujo Kerberos con Elliot.A*

## Flujo detallado del protocolo Kerberos

El protocolo Kerberos se compone de seis mensajes principales que se intercambian entre el cliente, el KDC y el servidor de aplicación. Cada mensaje tiene una función específica y utiliza cifrado simétrico para proteger la información.

El primer mensaje, AS-REQ, es enviado por el cliente al Servicio de Autenticación (AS). Si el cliente no incluye datos de pre-autenticación, el KDC responde con un error KRB5KDC_ERR_PREAUTH_REQUIRED, indicando que debe autenticarse primero. Este comportamiento es el predeterminado en la mayoría de los dominios y protege contra ataques de fuerza bruta y AS-REP Roasting.

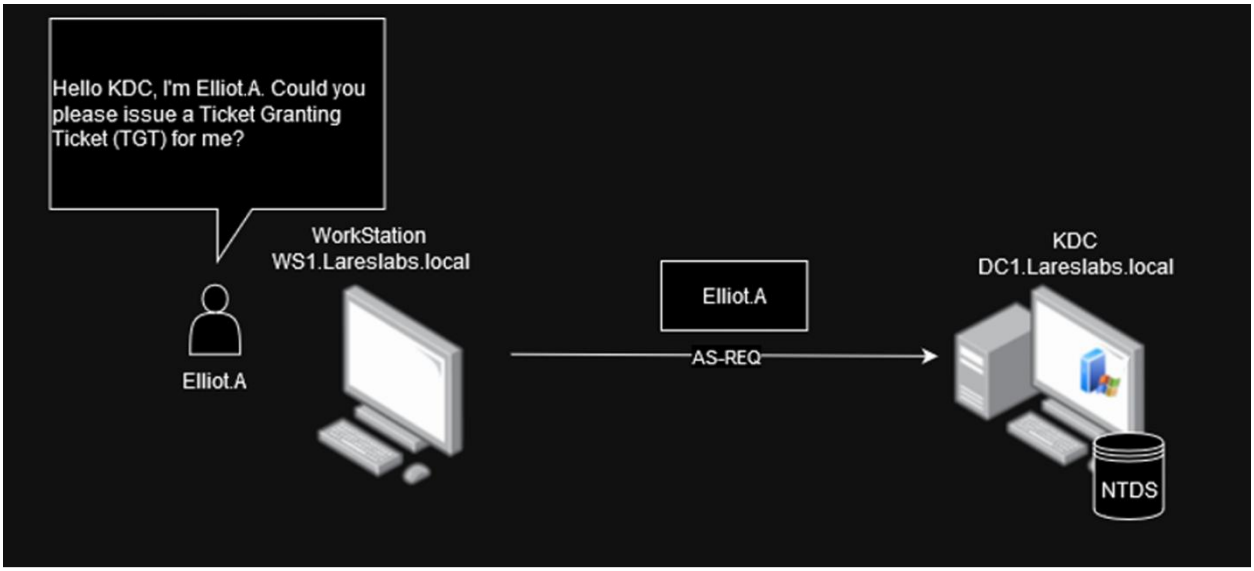



*Figura 4 — AS-REQ sin pre-autenticación*

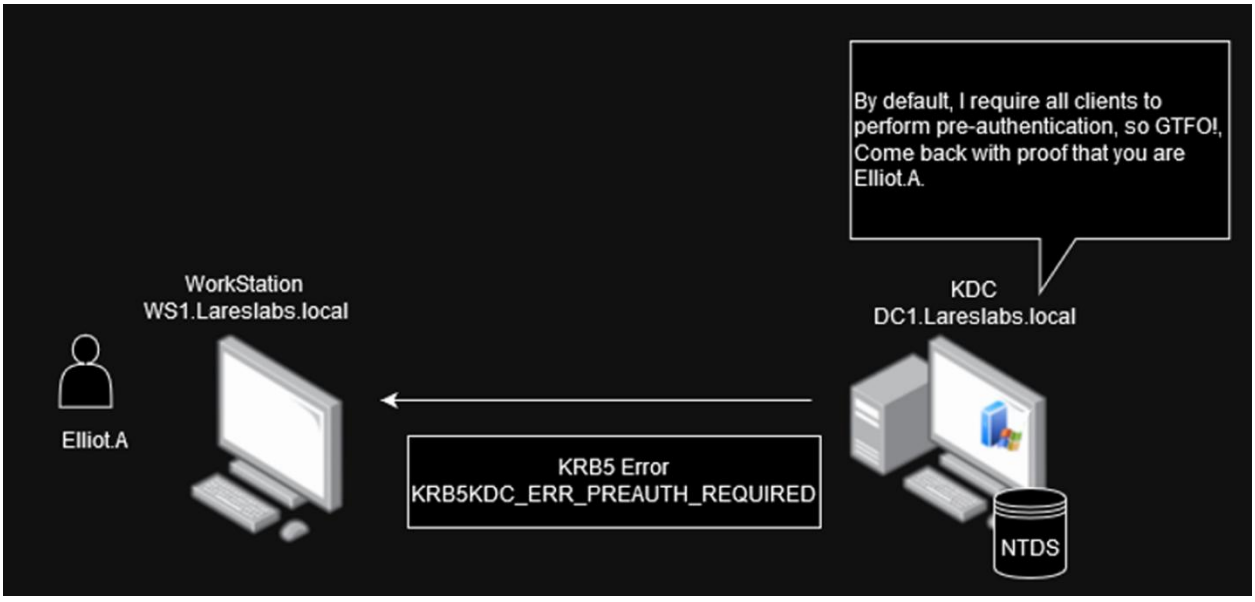



*Figura 5 - Error KRB5KDC_ERR_PREAUTH_REQUIRED*

Una vez que el cliente envía su timestamp cifrado con su clave secreta (derivada de la contraseña), el AS verifica la identidad y responde con un AS-REP que contiene el TGT (Ticket-Granting Ticket) y una clave de sesión. El TGT está cifrado con la clave del servicio krbtgt y tiene una vida útil limitada.

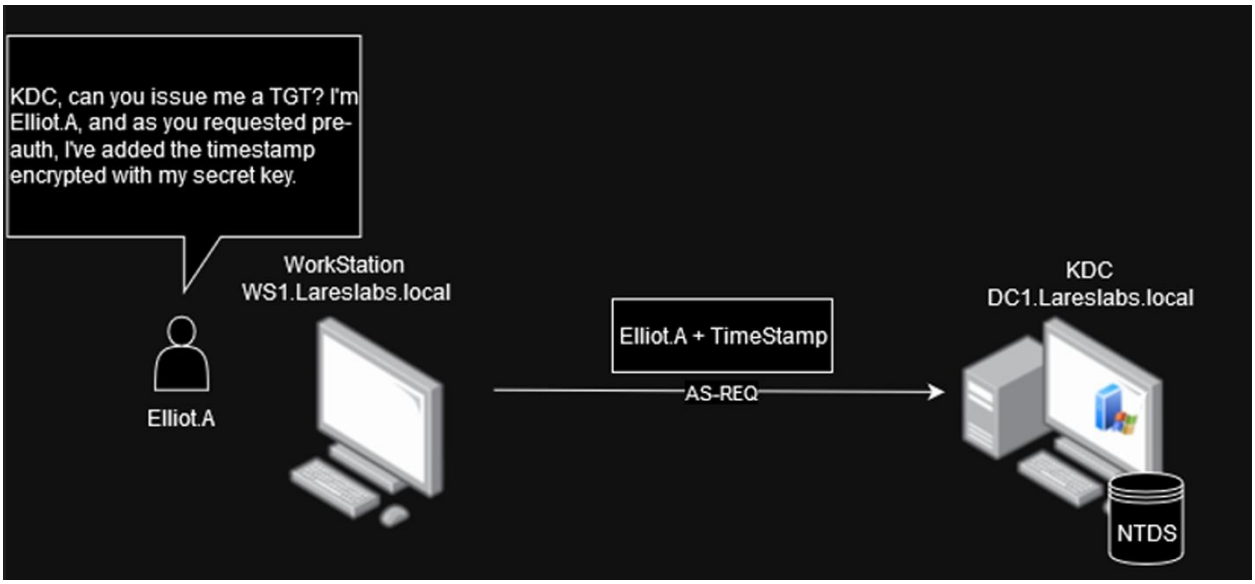



*Figura 6 - AS-REQ con timestamp cifrado*

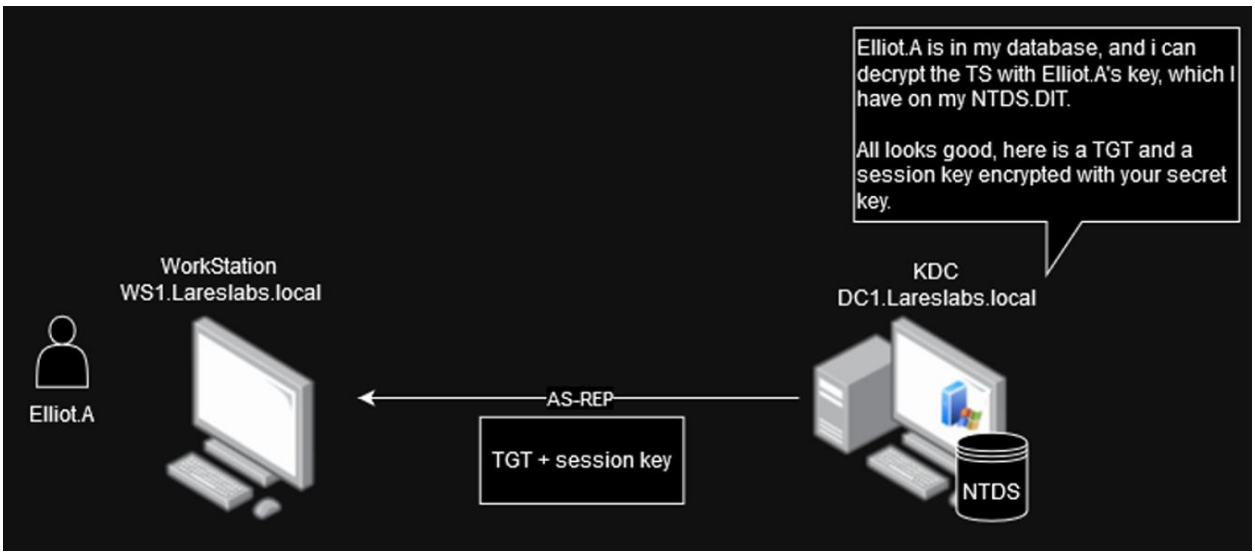



*Figura 7 - AS-REP: respuesta del KDC con TGT*

Posteriormente, cuando el cliente desea acceder a un servicio específico, envía un TGS-REQ al Servicio de Concesión de Tickets (TGS), incluyendo el TGT y un autenticador cifrado con la clave de sesión. El TGS verifica el TGT, valida el autenticador y responde con un TGS-REP que contiene el ticket de servicio (ST) cifrado con la clave del servidor destino.

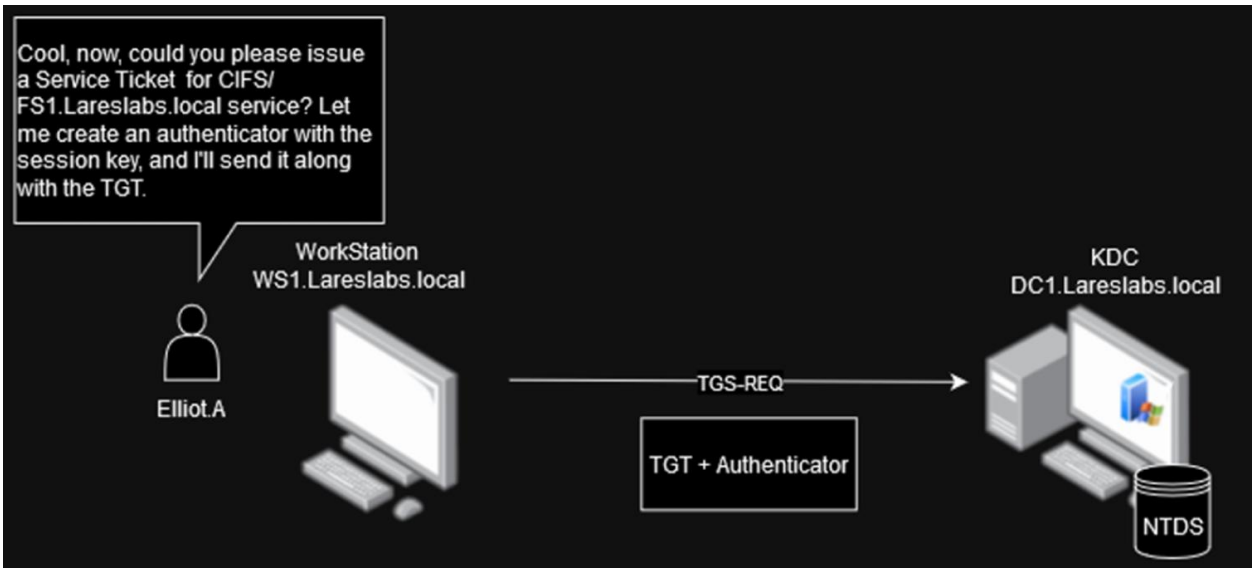



*Figura 8 - TGS-REQ: solicitud de ticket de servicio*

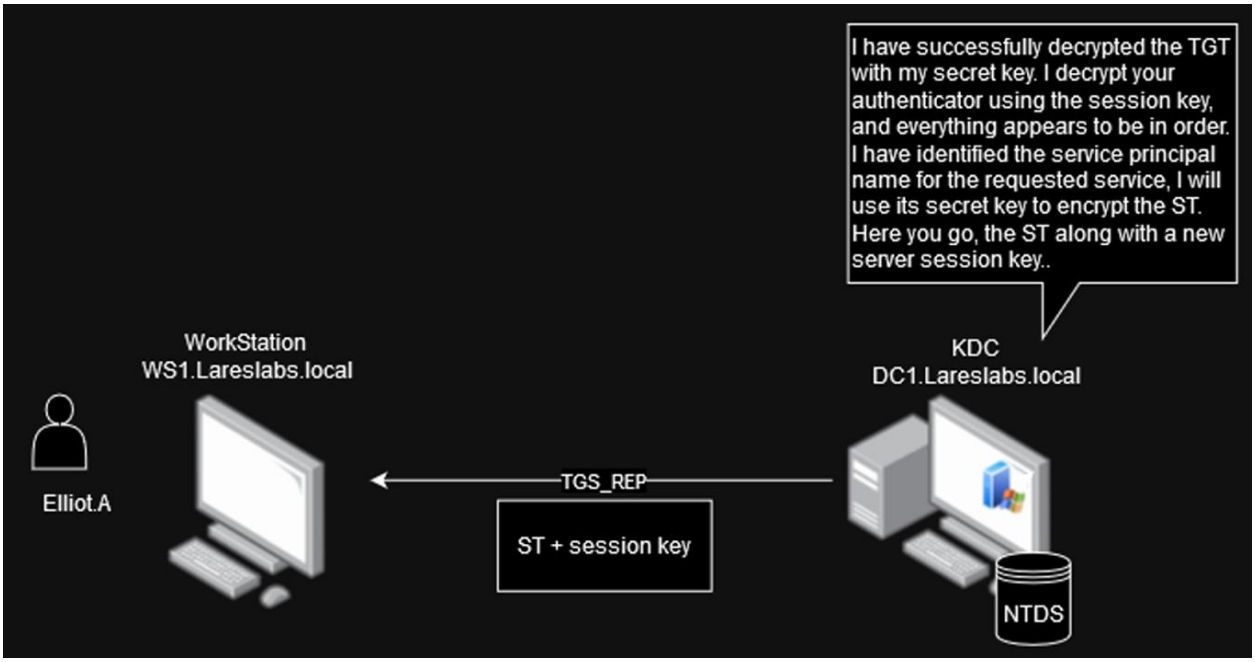



*Figura 9 - TGS-REP: entrega del ticket de servicio*

Finalmente, el cliente envía el AP-REQ al servidor de aplicación con el ticket de servicio y un nuevo autenticador. Si el servidor requiere autenticación mutua, responde con un AP-REP que contiene un timestamp cifrado con la clave de sesión del servicio, demostrando que es legítimo.

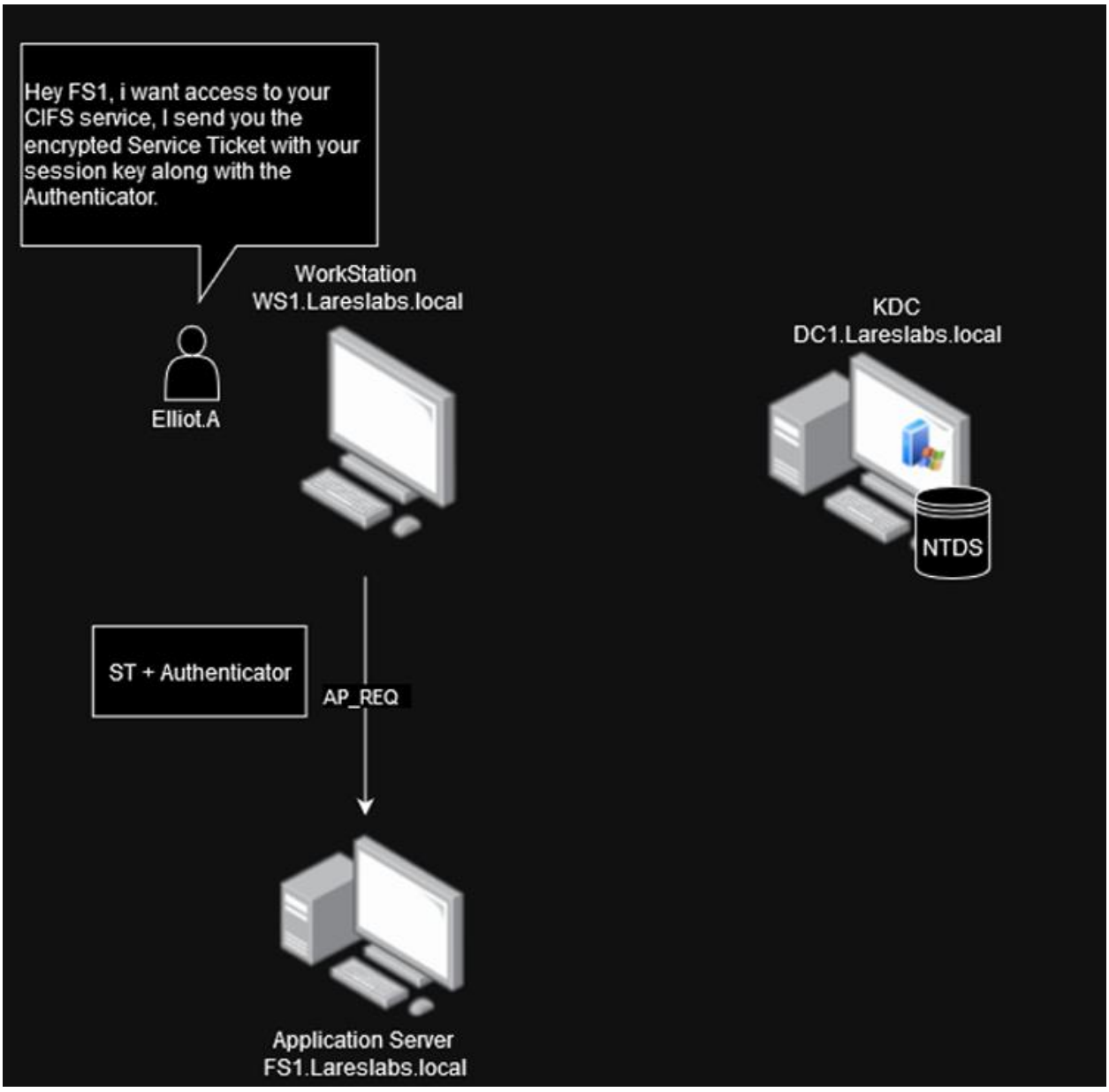
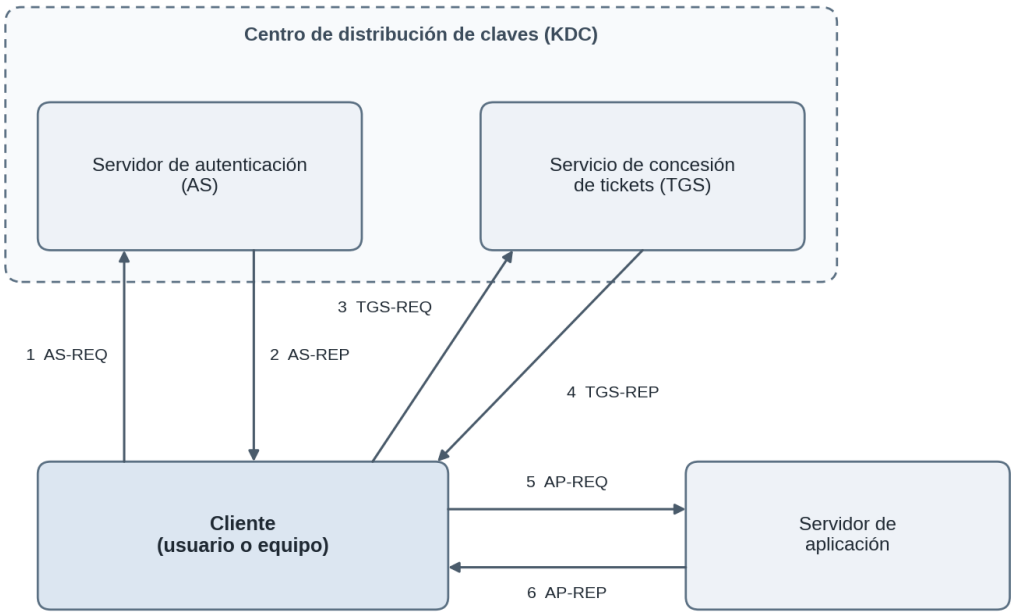



*Figura 10 - AP-REQ: solicitud al servidor de aplicación*




*Las contraseñas nunca viajan por la red; se usan tickets y claves de sesión con marca de tiempo.*

*Diagrama 3 - Intercambio de mensajes del protocolo Kerberos*

## PKINIT: autenticación con certificados

PKINIT (*Public Key Cryptography for Initial Authentication in Kerberos*) es un mecanismo de pre-autenticación que usa certificados X.509 en lugar de la contraseña del usuario. El cliente firma un timestamp con su clave privada y envía su certificado al KDC; el AS verifica la firma contra la clave pública del certificado y, si todo es correcto, emite el TGT. Esto permite usar tarjetas inteligentes y otros dispositivos criptográficos, y es la base de la autenticación fuerte en entornos Windows modernos.

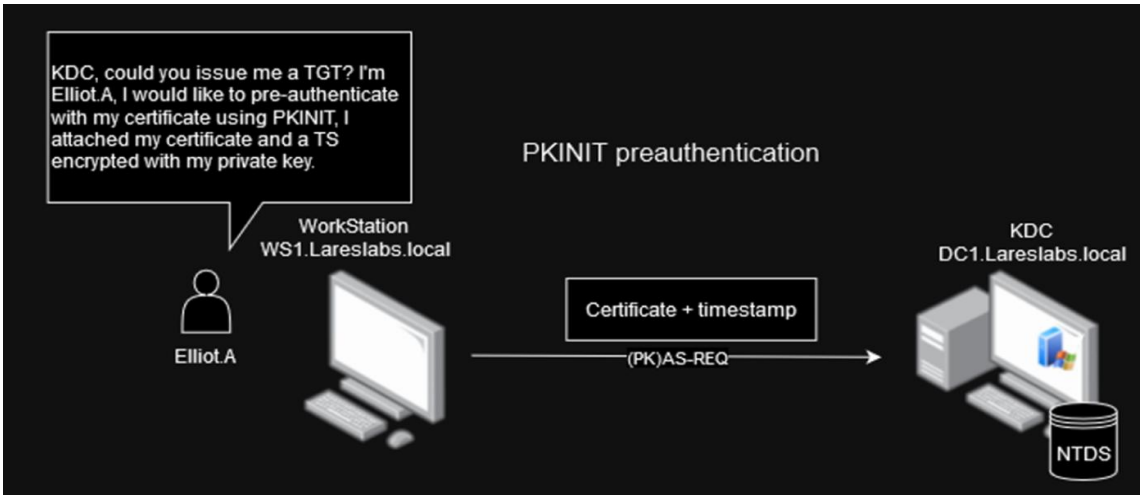



*Figura 11 - Pre-autenticación PKINIT con certificados X.509*

# Niveles de seguridad

La defensa en profundidad parte de una idea simple: ningún mecanismo debe ser la única barrera. Las protecciones se organizan en capas, y cada capa atiende una responsabilidad distinta: el usuario, la red y la empresa (Diagrama 4 y Tabla 6).

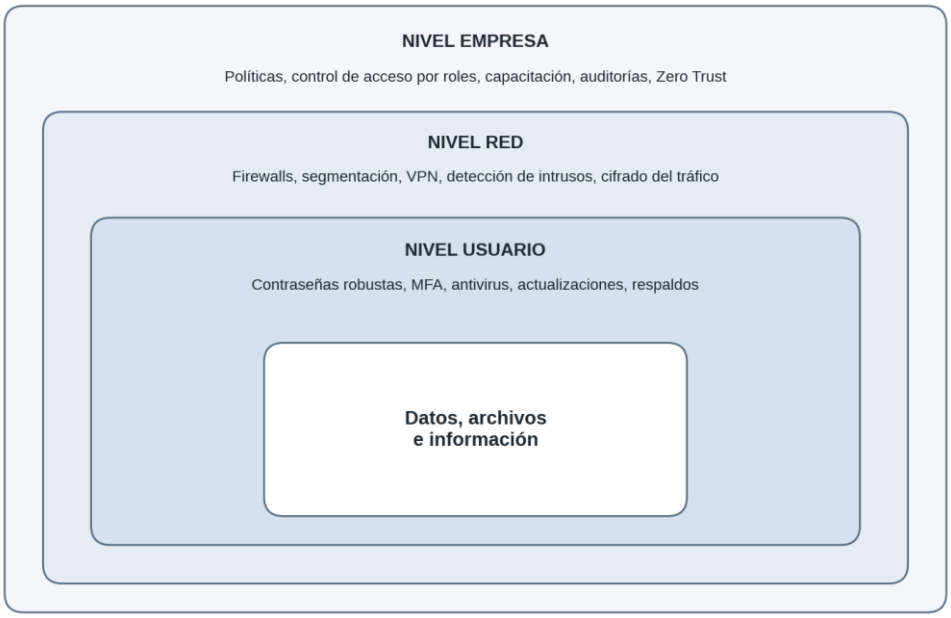



*Diagrama 4 - Defensa en profundidad: niveles de seguridad*

## Nivel usuario

Aquí se protege el equipo terminal (*endpoint*) y a la persona que lo usa, que suele ser el eslabón más débil. Conviene usar contraseñas robustas y únicas, autenticación multifactor, antivirus o EDR actualizado, actualizaciones automáticas del sistema y de las aplicaciones, y respaldos periódicos. También ayudan medidas como trabajar con una cuenta sin privilegios de administrador, no guardar contraseñas en el navegador, desactivar las macros de Office y desconfiar de correos y archivos adjuntos inesperados.

## Nivel red

El modelo tradicional de «castillo y foso» es fuerte en el perímetro y débil por dentro. En un sistema distribuido eso es peligroso, porque un equipo comprometido puede moverse lateralmente por una red plana hasta llegar a los servidores importantes. Entre las medidas están los firewalls, las VPN, el cifrado del tráfico (TLS, IPsec) y los sistemas de detección de intrusos (IDS), que analizan el tráfico en busca de señales como comunicaciones con servidores de comando y control. También se deben retirar los servicios inseguros expuestos a Internet, en particular el Escritorio Remoto (RDP), que es una vía habitual de entrada del ransomware.

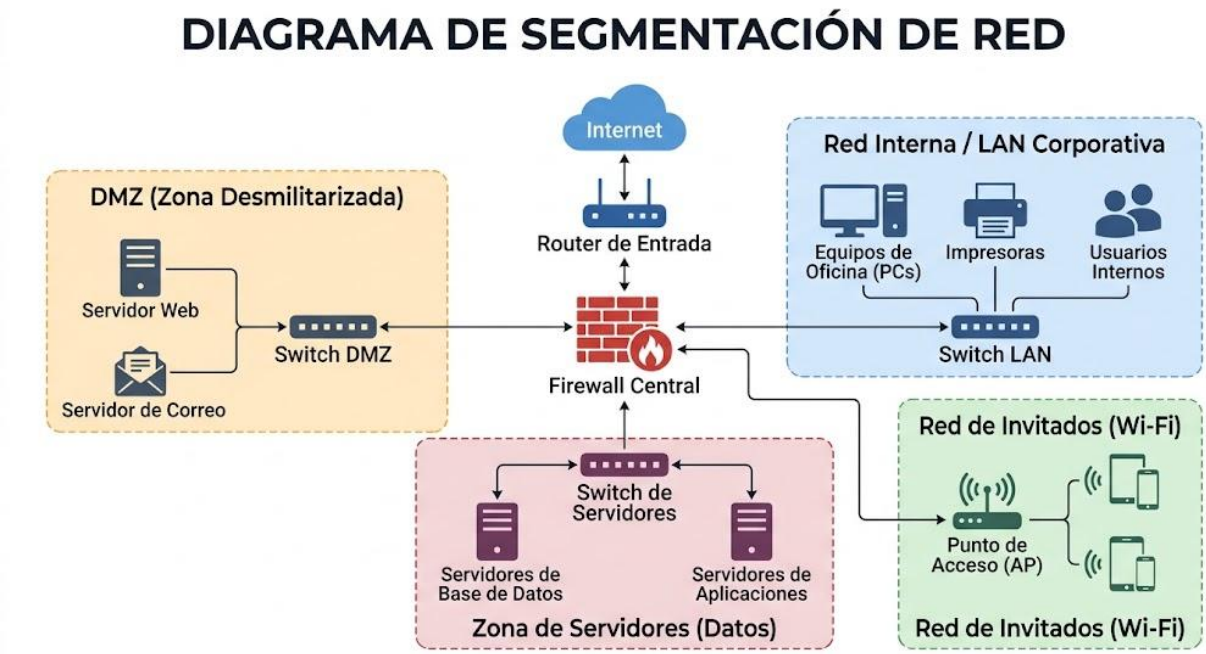



*Figura 12 - Ejemplo de segmentación de red con firewall*

La microsegmentación divide la red en zonas aisladas mediante firewalls de nueva generación o redes definidas por software, de modo que, por ejemplo, las estaciones de trabajo no vean directamente la base de datos operativa y una infección quede contenida.

## Nivel empresa

En una organización la seguridad también es un tema de gestión. Se requieren políticas de seguridad escritas, control de acceso por roles, capacitación del personal, auditorías periódicas, un plan de respuesta a incidentes y un análisis de riesgos continuo.

Un enfoque moderno es la arquitectura **Zero Trust** (confianza cero), normalizada en el documento NIST SP 800-207. En ella la ubicación en la red no otorga confianza: ninguna solicitud es confiable por defecto y cada sesión se verifica. Toda solicitud pasa por un punto de aplicación de políticas (PEP), como un proxy o una puerta de enlace de API, que permite o corta la conexión según el veredicto del punto de decisión de políticas (PDP). El PDP se compone de un motor de políticas (PE), que evalúa el contexto —identidad, estado del dispositivo, amenazas—, y un administrador de políticas (PA), que emite las credenciales de autorización (Diagrama 5).

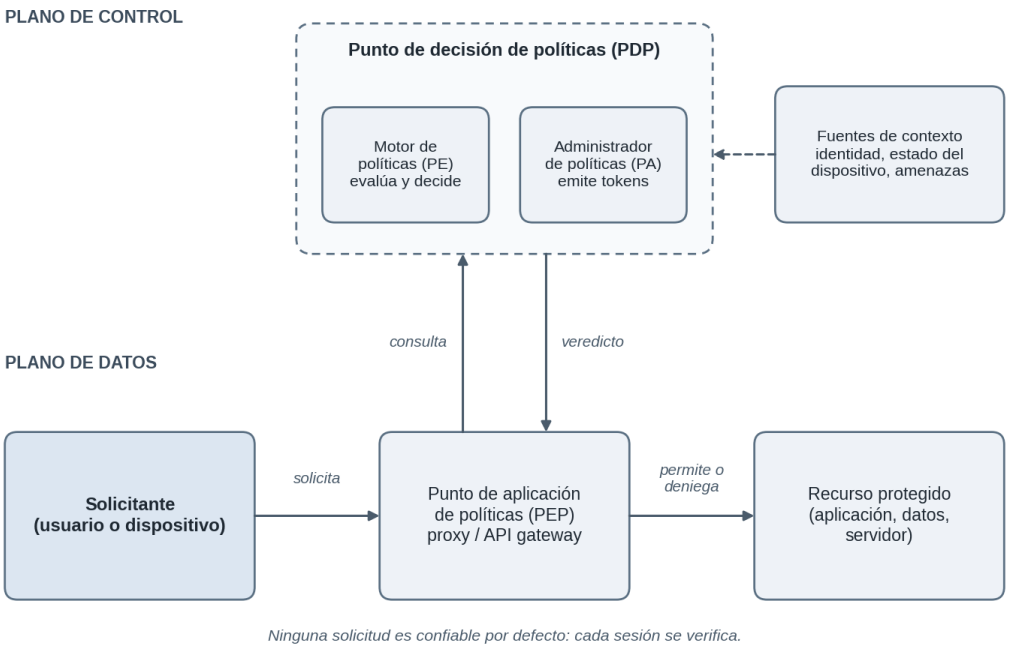



*Diagrama 5 - Arquitectura Zero Trust según NIST SP 800-207*

## Implementación práctica de Zero Trust

La arquitectura Zero Trust se implementa mediante varios componentes clave. El Punto de Aplicación de Políticas (PEP) actúa como intermediario entre el solicitante y el recurso protegido; ninguna comunicación ocurre sin pasar por él. El Punto de Decisión de Políticas (PDP) evalúa cada solicitud basándose en el contexto: identidad del usuario, estado del dispositivo, ubicación, hora y amenazas activas. El Motor de Políticas (PE) aplica las reglas definidas, y el Administrador de Políticas (PA) emite las credenciales o tokens necesarios para el acceso.

En la práctica, esto significa que un usuario que trabaja desde casa con un dispositivo corporativo actualizado y MFA puede acceder a un servidor de base de datos, pero el mismo usuario desde una red pública sin MFA es bloqueado, incluso si sus credenciales son correctas. Zero Trust no confía en la ubicación en la red como factor de confianza; verifica cada sesión de forma continua.

| Nivel | Qué protege | Amenazas frecuentes | Medidas |
|---|---|---|---|
| **Usuario** | El equipo, las cuentas y los archivos personales. | Phishing, troyanos, contraseñas débiles, ransomware. | Contraseñas robustas, MFA, antivirus o EDR, actualizaciones automáticas, respaldos, cuenta sin privilegios de administrador. |
| **Red** | Las comunicaciones y los servidores conectados. | Gusanos, movimiento lateral, DDoS, intercepción, RDP expuesto. | Firewalls, segmentación, VPN, IDS, cifrado del tráfico (TLS, IPsec), 802.1X. |
| **Empresa** | Los procesos, las personas y la información de la organización. | Amenazas internas, extorsión por ransomware, incumplimiento normativo. | Políticas, RBAC, capacitación, auditorías, análisis de riesgos, plan de respuesta, Zero Trust. |

*Tabla 6 - Medidas de seguridad por nivel*

# Análisis de problemas y administración de riesgos

## Análisis de riesgos

El riesgo no puede eliminarse por completo; se calcula y se gestiona con los recursos disponibles. Una forma simple de expresarlo es **riesgo = probabilidad × impacto**: una amenaza muy probable pero poco dañina puede importar menos que una improbable pero devastadora. La publicación NIST SP 800-30 propone una metodología con cuatro etapas (Diagrama 6):

- **Preparación:** definir el propósito de la evaluación, el alcance de los sistemas y procesos, los supuestos, y reunir información como la arquitectura de red y las regulaciones aplicables.
- **Ejecución:** catalogar amenazas (desde atacantes hasta cortes de energía), identificar vulnerabilidades y calcular el nivel de riesgo combinando probabilidad e impacto.
- **Comunicación:** presentar los resultados en un lenguaje claro para quienes toman decisiones, con un registro de riesgos y recomendaciones de mitigación.
- **Mantenimiento:** monitorear y reevaluar de forma periódica, porque el entorno y las tácticas de los atacantes cambian constantemente.




*Figura 13 - Pasos para crear y usar un Perfil Organizacional del CSF*




*Figura 14 - Uso del CSF para mejorar la comunicación de riesgos*

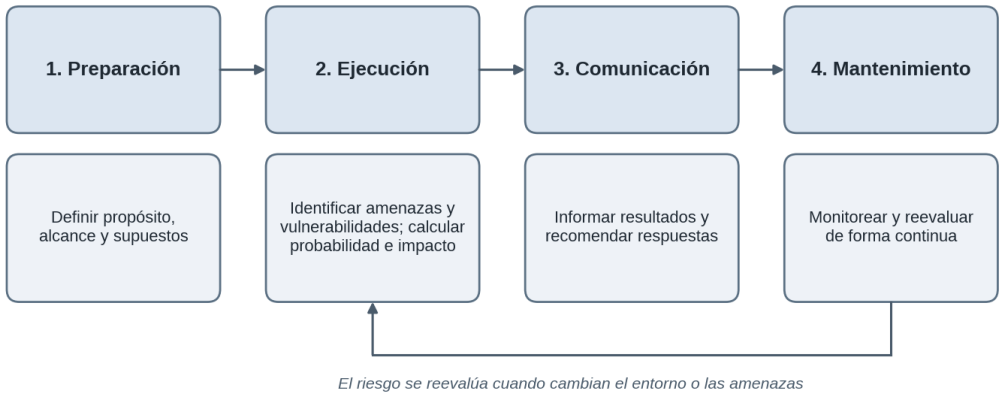



*Diagrama 6 - Etapas del análisis de riesgos según NIST SP 800-30*

Con los resultados, la dirección elige una respuesta para cada riesgo: mitigarlo (aplicar controles), aceptarlo (si es bajo y se vigila), transferirlo (por ejemplo, con un seguro) o evitarlo (eliminar la actividad que lo causa). La Tabla 7 muestra un ejemplo didáctico con una escala de 1 a 5; los valores son supuestos para ilustrar el método, no mediciones reales.

| Riesgo | Probabilidad (1-5) | Impacto (1-5) | Nivel (P ×I) | Respuesta sugerida |
|---|---|---|---|---|
| **Ransomware en el servidor de archivos** | 4 | 5 | 20 - Alto | Mitigar: respaldos 3-2-1-1-0, parches y EDR. |
| **Phishing dirigido a los usuarios** | 5 | 3 | 15 - Alto | Mitigar: MFA y capacitación. |
| **Falla eléctrica en el centro de datos** | 2 | 4 | 8 - Medio | Mitigar o transferir: UPS, planta de respaldo y seguro. |
| **Empleado descontento con acceso amplio** | 2 | 5 | 10 - Medio | Mitigar: mínimo privilegio y auditoría de accesos. |
| **Adware en equipos de laboratorio** | 4 | 1 | 4 - Bajo | Aceptar y vigilar: restringir instalaciones. |

*Tabla 7 - Ejemplo de matriz de riesgos (1-6 bajo, 7-14 medio, 15-25 alto)*

## Respuesta ante riesgos identificados

Una vez calculado el nivel de riesgo (probabilidad × impacto), la organización debe elegir una estrategia de respuesta. Las opciones son:

- **Mitigar:** aplicar controles para reducir la probabilidad o el impacto. Ejemplo: implementar MFA para reducir el riesgo de phishing.
- **Aceptar:** asumir el riesgo si es bajo y el costo de mitigarlo es mayor que el beneficio. Ejemplo: aceptar el riesgo de adware en equipos de laboratorio con políticas de reinstalación periódica.
- **Transferir:** compartir el riesgo con un tercero, como un seguro cibernético o un proveedor de servicios en la nube con SLA de seguridad.
- **Evitar:** eliminar la actividad que genera el riesgo. Ejemplo: deshabilitar RDP expuesto a Internet en lugar de solo protegerlo.

La elección depende de la tolerancia al riesgo de la organización, los recursos disponibles y el impacto potencial en la misión.

## Marcos de gestión de la seguridad

Para sostener la gestión del riesgo en el tiempo se usan marcos de referencia. El Marco de Ciberseguridad del NIST, en su versión 2.0 (2024), se organiza en seis funciones:

- **Gobernar:** definir la estrategia, las responsabilidades y las expectativas de riesgo de la organización.
- **Identificar:** inventariar hardware, software y servicios, y entender qué se debe proteger.
- **Proteger:** aplicar controles como gestión de identidades, MFA, capacitación y protección de los datos.
- **Detectar:** monitorear de forma continua para descubrir rápido actividades anómalas.
- **Responder:** activar los planes de respuesta a incidentes: análisis, contención y comunicación.
- **Recuperar:** restaurar servicios y datos a la normalidad en el menor tiempo posible.

Por su parte, la norma ISO/IEC 27001 define los requisitos certificables de un Sistema de Gestión de Seguridad de la Información (SGSI), y la ISO/IEC 27002:2022 ofrece 93 controles agrupados en cuatro temas: organizacionales, de personas, físicos y tecnológicos.

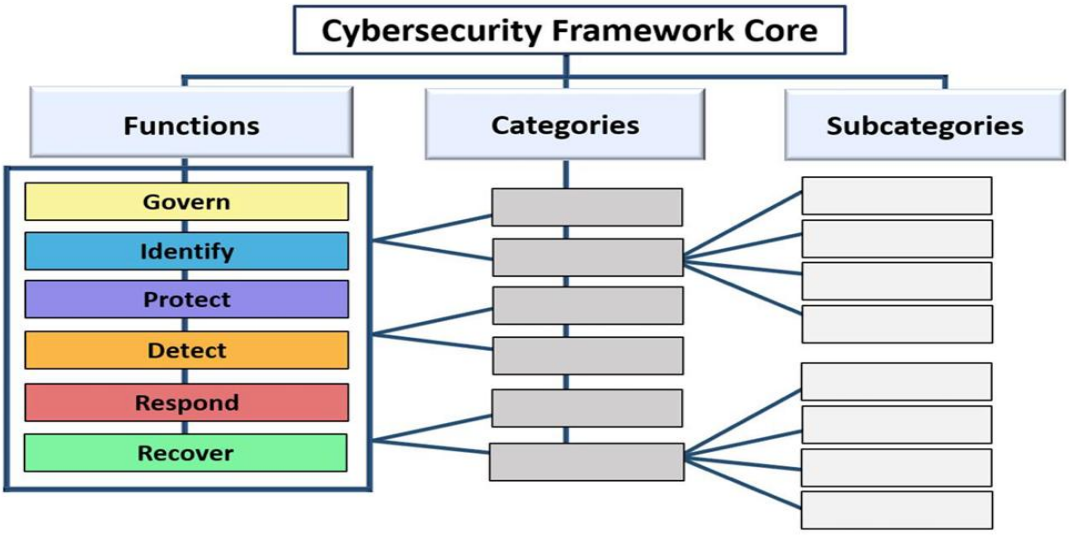



*Figura 15 - Estructura del CSF Core (Funciones, Categorías y Subcategorías)*

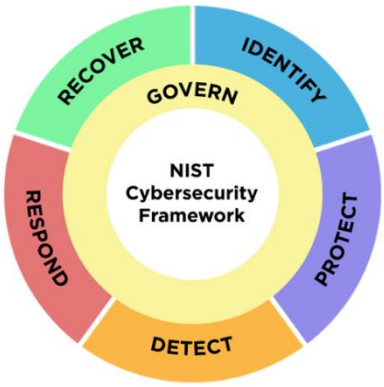



*Figura 13 - Las seis funciones del NIST CSF 2.0*

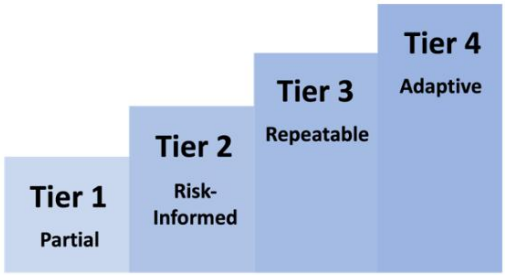



*Figura 14 - Niveles (Tiers) del NIST CSF 2.0*

Por su parte, la norma ISO/IEC 27001 define los requisitos certificables de un Sistema de Gestión de Seguridad de la Información (SGSI), y la ISO/IEC 27002:2022 ofrece 93 controles agrupados en cuatro temas: organizacionales, de personas, físicos y tecnológicos.

# Prevención de desastres y recuperación

## Prevención de desastres

Las interrupciones no vienen solo de ataques: los incendios, las inundaciones, los cortes de energía, las fallas de hardware y los errores humanos también pueden detener un sistema o destruir datos. Prevenir implica identificar estos escenarios, reducir su probabilidad y preparar la recuperación mediante un plan de continuidad de negocio y un plan de respuesta a incidentes que indique quién hace qué. Dos métricas ayudan a definir cuánta tolerancia se tiene: el **RTO** (tiempo objetivo de recuperación), que es el máximo tiempo que se puede estar sin operar, y el **RPO** (punto objetivo de recuperación), que es la máxima cantidad de datos que se puede perder, medida en tiempo.

## Plan de continuidad de negocio (BCP)

El Plan de Continuidad de Negocio (BCP) es un documento que describe cómo la organización mantendrá sus funciones críticas durante y después de una interrupción. Incluye:

1. **Análisis de impacto en el negocio (BIA):** identificar procesos críticos y el tiempo máximo que pueden estar detenidos.
2. **Estrategias de recuperación:** definir sitios alternos, equipos de respaldo, proveedores de respaldo y procedimientos manuales temporales.
3. **Equipo de respuesta:** asignar roles y responsabilidades, con cadenas de comunicación alternativas.
4. **Pruebas y mantenimiento:** realizar simulacros periódicos para validar que el plan funciona y actualizarlo según cambien los sistemas.

El BCP complementa al Plan de Respuesta a Incidentes (IRP), que se enfoca en contener y erradicar el incidente, mientras que el BCP se enfoca en mantener o restaurar las operaciones del negocio.

## Estrategia de respaldos 3-2-1-1-0

La estrategia de respaldo recomendada hoy es 3-2-1-1-0 (Tabla 8), una evolución de la regla 3-2-1, pensada porque el ransomware moderno busca borrar o cifrar también las copias conectadas a la red. Es importante distinguir respaldo de simple sincronización: si un archivo cifrado se sincroniza, la «copia» también queda inutilizable. Por eso la copia fuera de línea o inmutable y las pruebas de restauración son indispensables.




*Figura 15 - Esquema visual de la estrategia 3-2-1-1-0*

| Elemento | Qué significa | Para qué sirve |
|---|---|---|
| **3** | Tres copias de los datos (producción más dos respaldos). | Evita depender de una sola copia. |
| **2** | Dos tipos de medios distintos (discos, nube o cinta). | Reduce el riesgo de que una falla afecte a todo. |
| **1** | Una copia en un sitio remoto. | Protege ante incendio, inundación o robo. |
| **1** | Una copia fuera de línea, inmutable o aislada de la red. | Impide que el ransomware la cifre o la borre. |
| **0** | Cero errores al verificar la restauración. | Comprueba que los respaldos realmente sirven. |

*Tabla 8 - Componentes de la estrategia de respaldo 3-2-1-1-0*

## Tolerancia a fallos en sistemas distribuidos

En un sistema distribuido, mientras más nodos hay, más probable es que alguno falle. Los servidores restantes deben ponerse de acuerdo sobre el estado de los datos, lo que se conoce como el problema del **consenso**. Hay dos modelos de fallo: *Crash Fault Tolerance* (CFT), donde un nodo que falla simplemente se detiene, y *Byzantine Fault Tolerance* (BFT), donde un nodo comprometido puede mentir o enviar mensajes contradictorios.

Paxos y Raft resuelven el consenso bajo CFT. Paxos es teóricamente sólido pero difícil de implementar; Raft se diseñó para ser comprensible, con un líder fuerte, elección por temporizadores y replicación de registros. Ambos toleran f caídas en un clúster de n = 2f + 1 nodos (en uno de cinco pueden fallar dos). Cuando se debe asumir que un nodo puede ser tomado por un atacante, como en redes públicas o en blockchain, se usa PBFT, que requiere al menos 3f + 1 nodos para tolerar f nodos maliciosos, a cambio de una mayor sobrecarga de mensajes [14] (Tabla 9).

| Algoritmo | Fallos que tolera | Límite | Características |
|---|---|---|---|
| **Paxos** | Caídas de nodos (CFT). | f fallos con n ≥ 2f + 1. | Proponentes, aceptores y aprendices; sólido en teoría pero difícil de implementar. |
| **Raft** | Caídas de nodos (CFT). | f fallos con n ≥ 2f + 1. | Líder único, elecciones por temporizadores y replicación de registros; más fácil de entender. |
| **PBFT** | Nodos maliciosos (BFT). | f nodos maliciosos con n ≥ 3f + 1. | Tres fases (pre-preparación, preparación y compromiso); mayor sobrecarga de mensajes. |

*Tabla 9 - Comparación de algoritmos de consenso*

## Algoritmos de consenso: Paxos, Raft y PBFT

**Ejemplo práctico: consenso en un clúster de 5 nodos**

Consideremos un clúster de 5 servidores que deben ponerse de acuerdo sobre el estado de una base de datos distribuida. Si usamos Raft (CFT), el sistema puede tolerar la caída de 2 nodos (n = 2f + 1, con f = 2). Los 3 nodos restantes eligen un líder y continúan operando. Si el líder falla, los seguidores inician una nueva elección por temporizadores y eligen un nuevo líder en segundos.

Si en cambio usamos PBFT (BFT), el sistema puede tolerar 1 nodo malicioso (n = 3f + 1, con f = 1). Los 4 nodos honestos deben ejecutar tres fases de votación (pre-preparación, preparación y compromiso) para asegurar que el nodo malicioso no pueda alterar el consenso. Esto requiere más mensajes y tiempo, pero protege contra ataques bizantinos.

La elección entre CFT y BFT depende del entorno: en una red corporativa controlada, Raft es suficiente; en una red pública o blockchain, se necesita PBFT o sus variantes.

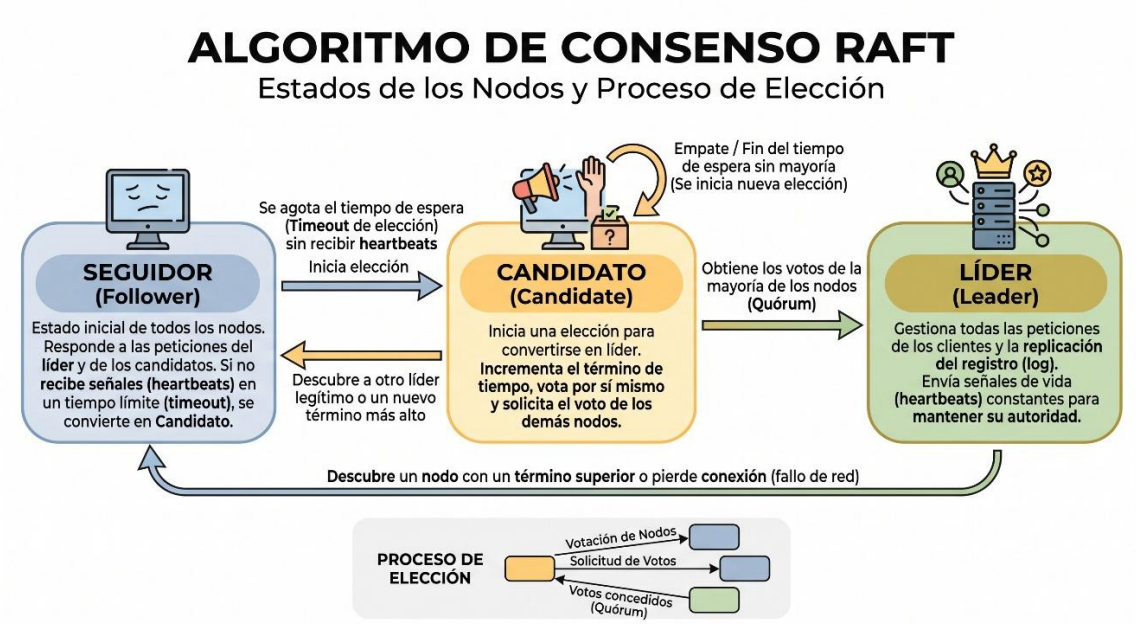



*Figura 16 - Funcionamiento del algoritmo Raft*

# Seguridad de hardware, software, archivos e información

Las medidas anteriores se concretan en controles sobre cada tipo de activo. La Tabla 10 resume los problemas posibles y sus soluciones, y a continuación se explica cada área.

## Seguridad del hardware

Las fallas no vienen solo del ciberespacio: los centros de cómputo necesitan protección contra robo, intervención física y condiciones ambientales. En línea con los controles físicos de la ISO 27002, se usan supresores de picos, sistemas de alimentación ininterrumpida (UPS) redundantes, control de temperatura, cerraduras, autenticación biométrica, cámaras de vigilancia y la norma IEEE 802.1X, que impide que dispositivos no autorizados se conecten a puertos de red desatendidos. El cifrado de discos evita que el robo de una unidad exponga su contenido.




*Figura 17 - Medidas de seguridad física en centro de datos*

## Seguridad del software

El software del sistema operativo, de las aplicaciones y de los hipervisores tiene defectos, y los atacantes aprovechan especialmente el software desactualizado expuesto a Internet. La gestión de parches debe ser sistemática y priorizada por riesgo; una referencia útil es el catálogo de vulnerabilidades explotadas conocidas (KEV) de CISA, que lista las fallas que ya se usan en ataques reales. También se aplican el principio de mínimo privilegio, el antimalware y las configuraciones seguras. Para el software que se desarrolla internamente, el listado OWASP Top 10 sirve de guía para evitar fallas como la inyección de código y las configuraciones débile.

FIGURA 23
**LOGO DE OWASP TOP 10**




El Proyecto Abierto de Seguridad en Aplicaciones Web (OWASP) es una fundación sin fines de lucro que trabaja para mejorar la seguridad del software. El 'Top 10' es su documento de referencia que identifica los diez riesgos de seguridad más críticos en aplicaciones web.

*Figura 18 - OWASP Top 10: riesgos de seguridad en aplicaciones*

## Seguridad de los archivos

En el nivel de archivos se aplican permisos y listas de control de acceso (ACL) basados en el mínimo privilegio: cada usuario o proceso solo debe leer o modificar lo que necesita. Quitar los privilegios de administrador local a los usuarios comunes dificulta que un virus modifique el sistema o el registro de Windows sin activar controles como el UAC. A esto se suman el cifrado de datos en reposo (por ejemplo, AES-256), los respaldos y, en el caso de archivos compartidos por red, canales protegidos con TLS o IPsec.

## Seguridad de la información

La información debe mantenerse confidencial, íntegra y disponible [19]. Para lograrlo se clasifican los datos según su sensibilidad, se cifran en tránsito y en reposo, se controla quién accede mediante roles, se respaldan y se capacita a las personas, porque muchas filtraciones comienzan con un error humano. En redes, las transferencias entre nodos —incluidos los sistemas de archivos de red— deben autenticarse y viajar dentro de canales cifrados que preserven su integridad.

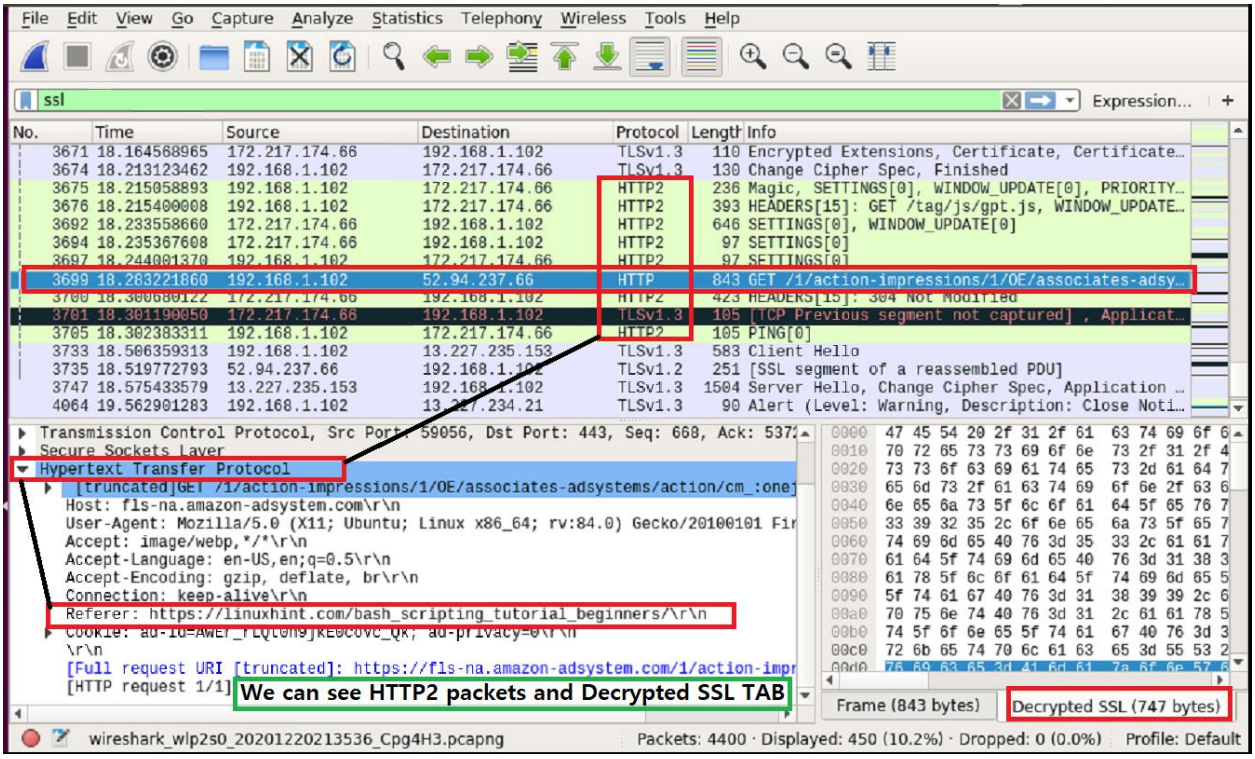



*Figura 19 - Tráfico cifrado con TLS en Wireshark*

| Área | Problemas posibles | Soluciones recomendadas |
|---|---|---|
| **Hardware** | Robo, acceso físico no autorizado, fallas eléctricas, sobrecalentamiento, dispositivos desconocidos en la red. | Control de acceso físico y cámaras, UPS y supresores de picos, climatización, 802.1X, cifrado de discos. |
| **Software** | Vulnerabilidades sin parchear, malware, configuraciones débiles, errores de programación. | Gestión de parches priorizada (catálogo KEV), antivirus o EDR, mínimo privilegio, desarrollo seguro (OWASP Top 10). |
| **Archivos** | Acceso indebido, borrado accidental, cifrado por ransomware, robo de unidades. | Permisos y ACL, cifrado en reposo (p. ej., AES-256), respaldos 3-2-1-1-0. |
| **Información** | Fuga de datos, interceptación en tránsito, alteración o pérdida. | Clasificación de datos, cifrado en tránsito (TLS, IPsec), control de acceso por roles, respaldos y capacitación. |

*Tabla 10 - Problemas frecuentes y soluciones por área*

# Conclusión general

Los sistemas distribuidos permiten compartir recursos y procesar información más allá de un solo equipo, pero esa conexión hace que una debilidad individual pueda afectar a todos. Un troyano que instala un usuario, junto con una contraseña débil o un sistema sin parches, puede convertirse en un gusano o en un ransomware que paralice toda una organización.

A lo largo del trabajo vimos que las amenazas (interrupción, intercepción, modificación y fabricación), los distintos tipos de malware y los diferentes intrusos —desde un script kiddie hasta grupos criminales organizados o un empleado con acceso legítimo— obligan a abandonar la idea de un perímetro único. La respuesta es la defensa en profundidad: autenticación fuerte (MFA, Kerberos), control de acceso con mínimo privilegio, medidas específicas para el usuario, la red y la empresa, y modelos como Zero Trust, que verifican cada solicitud.

Como el riesgo no desaparece, hay que administrarlo: analizarlo con metodologías como NIST SP 800-30, apoyarse en marcos como NIST CSF 2.0 e ISO/IEC 27002, y prepararse para fallar con respaldos 3-2-1-1-0, pruebas de restauración y algoritmos de consenso tolerantes a fallos. Proteger el hardware, el software, los archivos y la información exige combinar tecnología, procedimientos y personas capacitadas. En conclusión, la seguridad no es un producto que se instala una vez, sino un proceso continuo de prevención, detección, respuesta y mejora.

# Referencias


1. Malwarebytes. *Qué es el malware: definición de malware, tipos y protección*. https://www.malwarebytes.com/es/malware
2. Kaspersky. *Tipos de malware y ejemplos*. https://latam.kaspersky.com/resource-center/threats/types-of-malware
3. Trend Micro. *Tipos de malware*. https://www.trendmicro.com/es_es/what-is/endpoint-security/types-of-malware.html
4. Microsoft. *Qué es el malware: definición y tipos*. Seguridad de Microsoft. https://www.microsoft.com/es-mx/security/business/security-101/what-is-malware
5. INCIBE. *Qué son los virus: tipos, métodos de propagación y consecuencias*. https://www.incibe.es/node/493997
6. McAfee. *9 tipos de hackers y sus motivaciones*. https://www.mcafee.com/blogs/es-mx/family-safety/9-tipos-de-hackers-y-sus-motivaciones/
7. WeLiveSecurity. *Qué tipos de hacker existen y qué los diferencia*. https://www.welivesecurity.com/es/otros-temas/tipos-hacker-diferencias/
8. Achirou. *Tipos de hackers: White, Black y Grey Hat*. https://cursos.achirou.com/blog/tipos-de-hackers/
9. Illumio. *Qué es el control de acceso basado en roles (RBAC)*. https://www.illumio.com/es-mx/cybersecurity-101/rbac
10. Acre Security. *Control de acceso basado en atributos (ABAC): qué es y cómo funciona*. https://www.acresecurity.com/es/blog/attribute-based-access-control-abac-what-it-is-and-how-it-works
11. IONOS. *Cómo funciona la autenticación Kerberos*. https://www.ionos.mx/digitalguide/servidores/seguridad/kerberos/
12. Neuman, C., Yu, T., Hartman, S. y Raeburn, K. (2005). *RFC 4120: The Kerberos Network Authentication Service (V5)*. IETF. https://www.rfc-editor.org/info/rfc4120/
13. Microsoft. *Introducción a la autenticación Kerberos en Windows Server*. Microsoft Learn. https://learn.microsoft.com/es-es/windows-server/security/kerberos/kerberos-authentication-overview
14. GeeksforGeeks. *Consensus algorithms in distributed system*. https://www.geeksforgeeks.org/operating-systems/consensus-algorithms-in-distributed-system/
15. CISA. *#StopRansomware Guide*. https://www.cisa.gov/stopransomware/ransomware-guide
16. Rose, S., Borchert, O., Mitchell, S. y Connelly, S. (2020). *Zero Trust Architecture (NIST SP 800-207)*. NIST. https://nvlpubs.nist.gov/nistpubs/specialpublications/NIST.SP.800-207.pdf

17. NIST. (2012). *Guide for Conducting Risk Assessments (NIST SP 800-30 Rev. 1)*. https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf
18. NIST. (2024). *The NIST Cybersecurity Framework (CSF) 2.0 (NIST CSWP 29)*. https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf
19. ISMS.online. *ISO 27002:2022, Security Controls. Complete Overview*. https://www.isms.online/iso-27002/
20. HYCU. *3-2-1 Backup Rule: How It Works + 6 Challenges*. https://www.hycu.com/blog/3-2-1-backup-rule-explained-how-it-works-why-it-matters
21. OWASP. *OWASP Top 10*. https://owasp.org/projects/top-ten
22. CISA. (2025). *Microsegmentation in Zero Trust Part One: Introduction and Planning*. https://www.cisa.gov/sites/default/files/2025-07/ZT-Microsegmentation-Guidance-Part-One_508c.pdf
23. Lares. *Kerberos Security Series, Part 1*. https://lares.com
24. National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. NIST CSWP 29.